



OVERALL ASSESSMENT: CRITICAL RISK

Privacy & Data Protection Governance

The governance of privacy and data protection within the programme must be anchored in a disciplined, risk-aware approach that reconciles the commercial imperative of an early Identity Platform rollout with the statutory obligations imposed by the GDPR and the expectations of the Security Certification Body. Central to this equilibrium is the rapid execution of a privacy impact assessment (PIA) that satisfies both the internal Privacy Board and the external audit regime. To achieve this, a dedicated privacy-board task force should be convened without delay, drawing on senior legal counsel, the Data Protection Officer (DPO), and representatives from the security and engineering teams. This task force will be charged with delivering a provisional lift of the current block on the Identity Platform for a tightly scoped pilot, while simultaneously preparing a fallback federated-identity solution that meets the certification criteria. The programme schedule must be amended to reflect a 60- to-day assessment window, ensuring that no component of the Identity Platform is deployed before the Privacy Board has rendered a formal decision. In practice, the task force will allocate a single reviewer to drive the PIA to completion within a hard deadline of thirty days. This accelerated timeline is essential because the planned deployment date of 1 April 2026 cannot be postponed without jeopardising downstream milestones in the AI Platform and Finance Integration Module. Should the Board refuse to endorse the pilot, the programme must be ready to switch instantly to a hybrid authentication fallback that has already been approved by the Security Certification Body. This fallback could take the form of a temporary multi-factor authentication (MFA) service that bypasses the blocked Identity Platform, thereby keeping the gateway functional while the assessment is pending. The fallback must be capable of supporting the same user-experience standards as the primary solution, and it must be documented as a provisional measure pending final approval. The Finance Integration Module, a critical conduit for monetary data, presents an additional vector of risk. If the Identity Platform cannot be cleared in time, the module should be redesigned to employ a GDPR-compliant decentralized authentication method that does not rely on the blocked platform. Such a redesign would not only satisfy the privacy board's concerns but also provide a resilient architecture that can accommodate future regulatory changes. In parallel, a federated-identity solution, already vetted by the Security Certification Body, should be positioned as a viable replacement for the centralized Identity Platform. This solution must be capable of delivering the required authorisation levels while preserving the privacy of personal data, thereby aligning with the programme's broader compliance framework. The Data Protection Impact Assessment (DPIA) must be submitted immediately, and a written commitment from the DPO to prioritise its review should be secured. Recognising that the DPO may be unable to meet the ten-week review window, the programme should engage an external DPO or interim compliance authority to grant provisional sign-off. This provisional approval will enable the Training Data Repository to be populated and the AI Platform to progress on schedule. If the DPO's timeline remains untenable, a temporary lawful basis—such as the use of pseudonymised data—can be employed to feed the repository, with a parallel data-masking pipeline that anonymises sensitive fields. In the interim, a synthetic data set may be used to train the AI models, ensuring that the development timeline is not compromised while full compliance is being finalised. To maintain the integrity of the overall security posture, the penetration test for the Network Infrastructure Upgrade should be re-scheduled to commence as soon as the upgrade is complete, with an expedited slot requested from the Security Certification Body. A provisional test environment that meets the body's minimum requirements must be provisioned, allowing the assessment to proceed without further delay. Should the DPIA or the DPO sign-off prove impossible within the stipulated timeframe, the programme must be prepared to implement a separate, privacy-sanitised repository for the AI Platform. This repository would ingest data through a GDPR-compliant pipeline that incorporates pseudonymisation and consent-driven collection, thereby satisfying the GDPR Compliance Framework while still supplying the training data required for the platform's operation. Finally, the audit system, which currently depends on the blocked Identity Platform, should be re-architected to use a dedicated audit-only single sign-on (SSO) instance that is fully compliant with privacy standards. By decoupling the audit function from the primary authentication mechanism, the programme eliminates a single point of failure and ensures that audit activities can continue unabated regardless of the status of the Identity Platform. This architectural adjustment, combined with the aforementioned measures, provides a robust, multi-layered response to the privacy and data-protection risks identified, ensuring that the programme can meet its 1 April 2026 deadline without compromising regulatory compliance or security integrity.

Regulatory Compliance & Audit Log Retention

The regulatory compliance framework governing audit-log retention is a cornerstone of the programme's risk-management posture, and it demands a disciplined, evidence-based approach that satisfies statutory obligations while enabling the planned migration to the cloud. Central to this effort is the need to obtain a formal legal ruling that cloud-replicated audit logs satisfy the twelve-month statutory retention requirement. Once such a ruling is secured, the next step is to construct a secure, immutable cloud archive that can be relied upon as the definitive record of system activity. This archive must be presented to the Compliance Authority for explicit sign-off before the legacy data centre can be decommissioned; alternatively, if the cloud solution is deemed insufficient, the on-premises storage lease should be extended to cover the required retention period, thereby avoiding any breach of record-keeping obligations. In parallel with the legal ruling, the programme must expedite a comprehensive legal assessment of the cloud-replicated audit-log storage model. The assessment should culminate in the implementation of a compliant audit-log archive in the cloud, together with a written exemption or a deadline extension from the Compliance Authority. This dual-track approach ensures that the data centre decommission can proceed without contravening statutory requirements, while also providing a clear audit trail for any future regulatory inquiry. A formal legal opinion confirming that the cloud-replicated audit logs meet the statutory twelve-month retention window must be obtained and promptly presented to the Compliance Authority. The purpose of this submission is to lift the current operational block that hampers progress. Should the Authority deem the cloud solution unsatisfactory, the programme must be prepared to negotiate a temporary on-premises storage extension or to adjust the lease expiry so that it aligns with the compliance window. This contingency planning is essential to maintain momentum while respecting regulatory constraints. Securing a formal compliance sign-off that the cloud-based audit logs satisfy the twelve-month statutory record-keeping requirement is another critical milestone. If the Compliance Authority rejects the cloud-based approach, the programme must retain a minimal on-premises archive for the required period and defer the data centre decommission until after 31 March 2027, or negotiate a lease extension that accommodates the statutory window. This decision will directly influence the timing of the cloud migration and must be reflected in the overall project schedule. To facilitate a seamless transition, a formal compliance sign-off should also be obtained for storing the required audit logs in a tamper-proof, cloud-based repository. In the event that the Authority does not grant this sign-off, a statutory extension must be pursued. The migration schedule should be adjusted accordingly, ensuring that the data centre decommission does not breach any statutory record-keeping obligations. Given the inter-dependencies between certification, compliance, and migration, the programme should re-schedule the cloud migration to commence after the earliest possible certification date, which is projected to be post-10 August 2026. An interim certification or provisional approval from the Security Certification Body should be requested to permit limited migration activities while the full test is ongoing. Simultaneously, a temporary compliance waiver or a cloud-based audit-log archive that satisfies the twelve-month statutory requirement must be negotiated, and formal sign-off from the Compliance Authority must be secured before any decommissioning of the data centre. Both issues should be escalated to the Nexus Steering Board for rapid decision-making, ensuring that any bottlenecks are addressed promptly. If the Compliance Authority remains hesitant, a formal compliance waiver must be secured, or the migration plan should be redesigned so that the data centre remains operational until the Authority provides a signed approval. This redesign requires the preparation of a detailed compliance dossier that directly addresses the Authority's concerns, and the acquisition of a signed approval before any decommissioning activity can proceed. The programme closure date of 31 March 2027 is contingent upon the successful completion of the Production Gate milestone. A missed gate triggers a Regulatory Hold that blocks Production Deployment, jeopardising the entire schedule. To mitigate this risk, gate preparation should be front-loaded with the Production Gate approval and all prerequisite assurance packages completed by early December 2026. A thirty-day

 Full Narrative Report


OVERALL ASSESSMENT: CRITICAL RISK

Privacy & Data Protection Governance

The governance of privacy and data protection within the programme must be anchored in a disciplined, risk-aware approach that reconciles the commercial imperative of an early Identity Platform rollout with the statutory obligations imposed by the GDPR and the expectations of the Security Certification Body. Central to this equilibrium is the rapid execution of a privacy impact assessment (PIA) that satisfies both the internal Privacy Board and the external audit regime. To achieve this, a dedicated privacy-board task force should be convened without delay, drawing on senior legal counsel, the Data Protection Officer (DPO), and representatives from the security and engineering teams. This task force will be charged with delivering a provisional lift of the current block on the Identity Platform for a tightly scoped pilot, while simultaneously preparing a fallback federated-identity solution that meets the certification criteria. The programme schedule must be amended to reflect a 60- to-day assessment window, ensuring that no component of the Identity Platform is deployed before the Privacy Board has rendered a formal decision. In practice, the task force will allocate a single reviewer to drive the PIA to completion within a hard deadline of thirty days. This accelerated timeline is essential because the planned deployment date of 1 April 2026 cannot be postponed without jeopardising downstream milestones in the AI Platform and Finance Integration Module. Should the Board refuse to endorse the pilot, the programme must be ready to switch instantly to a hybrid authentication fallback that has already been approved by the Security Certification Body. This fallback could take the form of a temporary multi-factor authentication (MFA) service that bypasses the blocked Identity Platform, thereby keeping the gateway functional while the assessment is pending. The fallback must be capable of supporting the same user-experience standards as the primary solution, and it must be documented as a provisional measure pending final approval. The Finance Integration Module, a critical conduit for monetary data, presents an additional vector of risk. If the Identity Platform cannot be cleared in time, the module should be redesigned to employ a GDPR-compliant decentralized authentication method that does not rely on the blocked platform. Such a redesign would not only satisfy the privacy board's concerns but also provide a resilient architecture that can accommodate future regulatory changes. In parallel, a federated-identity solution, already vetted by the Security Certification Body, should be positioned as a viable replacement for the centralized Identity Platform. This solution must be capable of delivering the required authorisation levels while preserving the privacy of personal data, thereby aligning with the programme's broader compliance framework. The Data Protection Impact Assessment (DPIA) must be submitted immediately, and a written commitment from the DPO to prioritise its review should be secured. Recognising that the DPO may be unable to meet the ten-week review window, the programme should engage an external DPO or interim compliance authority to grant provisional sign-off. This provisional approval will enable the Training Data Repository to be populated and the AI Platform to progress on schedule. If the DPO's timeline remains untenable, a temporary lawful basis—such as the use of pseudonymised data—can be employed to feed the repository, with a parallel data-masking pipeline that anonymises sensitive fields. In the interim, a synthetic data set may be used to train the AI models, ensuring that the development timeline is not compromised while full compliance is being finalised. To maintain the integrity of the overall security posture, the penetration test for the Network Infrastructure Upgrade should be re-scheduled to commence as soon as the upgrade is complete, with an expedited slot requested from the Security Certification Body. A provisional test environment that meets the body's minimum requirements must be provisioned, allowing the assessment to proceed without further delay. Should the DPIA or the DPO sign-off prove impossible within the stipulated timeframe, the programme must be prepared to implement a separate, privacy-sanitised repository for the AI Platform. This repository would ingest data through a GDPR-compliant pipeline that incorporates pseudonymisation and consent-driven collection, thereby satisfying the GDPR Compliance Framework while still supplying the training data required for the platform's operation. Finally, the audit system, which currently depends on the blocked Identity Platform, should be re-architected to use a dedicated audit-only single sign-on (SSO) instance that is fully compliant with privacy standards. By decoupling the audit function from the primary authentication mechanism, the programme eliminates a single point of failure and ensures that audit activities can continue unabated regardless of the status of the Identity Platform. This architectural adjustment, combined with the aforementioned measures, provides a robust, multi-layered response to the privacy and data-protection risks identified, ensuring that the programme can meet its 1 April 2026 deadline without compromising regulatory compliance or security integrity.

Regulatory Compliance & Audit Log Retention

The regulatory compliance framework governing audit-log retention is a cornerstone of the programme's risk-management posture, and it demands a disciplined, evidence-based approach that satisfies statutory obligations while enabling the planned migration to the cloud. Central to this effort is the need to obtain a formal legal ruling that cloud-replicated audit logs satisfy the twelve-month statutory retention requirement. Once such a ruling is secured, the next step is to construct a secure, immutable cloud archive that can be relied upon as the definitive record of system activity. This archive must be presented to the Compliance Authority for explicit sign-off before the legacy data centre can be decommissioned; alternatively, if the cloud solution is deemed insufficient, the on-premises storage lease should be extended to cover the required retention period, thereby avoiding any breach of record-keeping obligations. In parallel with the legal ruling, the programme must expedite a comprehensive legal assessment of the cloud-replicated audit-log storage model. The assessment should culminate in the implementation of a compliant audit-log archive in the cloud, together with a written exemption or a deadline extension from the Compliance Authority. This dual-track approach ensures that the data centre decommission can proceed without contravening statutory requirements, while also providing a clear audit trail for any future regulatory inquiry. A formal legal opinion confirming that the cloud-replicated audit logs meet the statutory twelve-month retention window must be obtained and promptly presented to the Compliance Authority. The purpose of this submission is to lift the current operational block that hampers progress. Should the Authority deem the cloud solution unsatisfactory, the programme must be prepared to negotiate a temporary on-premises storage extension or to adjust the lease expiry so that it aligns with the compliance window. This contingency planning is essential to maintain momentum while respecting regulatory constraints. Securing a formal compliance sign-off that the cloud-based audit logs satisfy the twelve-month statutory record-keeping requirement is another critical milestone. If the Compliance Authority rejects the cloud-based approach, the programme must retain a minimal on-premises archive for the required period and defer the data centre decommission until after 31 March 2027, or negotiate a lease extension that accommodates the statutory window. This decision will directly influence the timing of the cloud migration and must be reflected in the overall project schedule. To facilitate a seamless transition, a formal compliance sign-off should also be obtained for storing the required audit logs in a tamper-proof, cloud-based repository. In the event that the Authority does not grant this sign-off, a statutory extension must be pursued. The migration schedule should be adjusted accordingly, ensuring that the data centre decommission does not breach any statutory record-keeping obligations. Given the inter-dependencies between certification, compliance, and migration, the programme should re-schedule the cloud migration to commence after the earliest possible certification date, which is projected to be post-10 August 2026. An interim certification or provisional approval from the Security Certification Body should be requested to permit limited migration activities while the full test is ongoing. Simultaneously, a temporary compliance waiver or a cloud-based audit-log archive that satisfies the twelve-month statutory requirement must be negotiated, and formal sign-off from the Compliance Authority must be secured before any decommissioning of the data centre. Both issues should be escalated to the Nexus Steering Board for rapid decision-making, ensuring that any bottlenecks are addressed promptly. If the Compliance Authority remains hesitant, a formal compliance waiver must be secured, or the migration plan should be redesigned so that the data centre remains operational until the Authority provides a signed approval. This redesign requires the preparation of a detailed compliance dossier that directly addresses the Authority's concerns, and the acquisition of a signed approval before any decommissioning activity can proceed. The programme closure date of 31 March 2027 is contingent upon the successful completion of the Production Gate milestone. A missed gate triggers a Regulatory Hold that blocks Production Deployment, jeopardising the entire schedule. To mitigate this risk, gate preparation should be front-loaded with the Production Gate approval and all prerequisite assurance packages completed by early December 2026. A thirty-day

Full Narrative Report



OVERALL ASSESSMENT: CRITICAL RISK

Privacy & Data Protection Governance

The governance of privacy and data protection within the programme must be anchored in a disciplined, risk-aware approach that reconciles the commercial imperative of an early Identity Platform rollout with the statutory obligations imposed by the GDPR and the expectations of the Security Certification Body. Central to this equilibrium is the rapid execution of a privacy impact assessment (PIA) that satisfies both the internal Privacy Board and the external audit regime. To achieve this, a dedicated privacy-board task force should be convened without delay, drawing on senior legal counsel, the Data Protection Officer (DPO), and representatives from the security and engineering teams. This task force will be charged with delivering a provisional lift of the current block on the Identity Platform for a tightly scoped pilot, while simultaneously preparing a fallback federated-identity solution that meets the certification criteria. The programme schedule must be amended to reflect a 60- to-day assessment window, ensuring that no component of the Identity Platform is deployed before the Privacy Board has rendered a formal decision. In practice, the task force will allocate a single reviewer to drive the PIA to completion within a hard deadline of thirty days. This accelerated timeline is essential because the planned deployment date of 1 April 2026 cannot be postponed without jeopardising downstream milestones in the AI Platform and Finance Integration Module. Should the Board refuse to endorse the pilot, the programme must be ready to switch instantly to a hybrid authentication fallback that has already been approved by the Security Certification Body. This fallback could take the form of a temporary multi-factor authentication (MFA) service that bypasses the blocked Identity Platform, thereby keeping the gateway functional while the assessment is pending. The fallback must be capable of supporting the same user-experience standards as the primary solution, and it must be documented as a provisional measure pending final approval. The Finance Integration Module, a critical conduit for monetary data, presents an additional vector of risk. If the Identity Platform cannot be cleared in time, the module should be redesigned to employ a GDPR-compliant decentralized authentication method that does not rely on the blocked platform. Such a redesign would not only satisfy the privacy board's concerns but also provide a resilient architecture that can accommodate future regulatory changes. In parallel, a federated-identity solution, already vetted by the Security Certification Body, should be positioned as a viable replacement for the centralized Identity Platform. This solution must be capable of delivering the required authorisation levels while preserving the privacy of personal data, thereby aligning with the programme's broader compliance framework. The Data Protection Impact Assessment (DPIA) must be submitted immediately, and a written commitment from the DPO to prioritise its review should be secured. Recognising that the DPO may be unable to meet the ten-week review window, the programme should engage an external DPO or interim compliance authority to grant provisional sign-off. This provisional approval will enable the Training Data Repository to be populated and the AI Platform to progress on schedule. If the DPO's timeline remains untenable, a temporary lawful basis—such as the use of pseudonymised data—can be employed to feed the repository, with a parallel data-masking pipeline that anonymises sensitive fields. In the interim, a synthetic data set may be used to train the AI models, ensuring that the development timeline is not compromised while full compliance is being finalised. To maintain the integrity of the overall security posture, the penetration test for the Network Infrastructure Upgrade should be re-scheduled to commence as soon as the upgrade is complete, with an expedited slot requested from the Security Certification Body. A provisional test environment that meets the body's minimum requirements must be provisioned, allowing the assessment to proceed without further delay. Should the DPIA or the DPO sign-off prove impossible within the stipulated timeframe, the programme must be prepared to implement a separate, privacy-sanitised repository for the AI Platform. This repository would ingest data through a GDPR-compliant pipeline that incorporates pseudonymisation and consent-driven collection, thereby satisfying the GDPR Compliance Framework while still supplying the training data required for the platform's operation. Finally, the audit system, which currently depends on the blocked Identity Platform, should be re-architected to use a dedicated audit-only single sign-on (SSO) instance that is fully compliant with privacy standards. By decoupling the audit function from the primary authentication mechanism, the programme eliminates a single point of failure and ensures that audit activities can continue unabated regardless of the status of the Identity Platform. This architectural adjustment, combined with the aforementioned measures, provides a robust, multi-layered response to the privacy and data-protection risks identified, ensuring that the programme can meet its 1 April 2026 deadline without compromising regulatory compliance or security integrity.

Regulatory Compliance & Audit Log Retention

The regulatory compliance framework governing audit-log retention is a cornerstone of the programme's risk-management posture, and it demands a disciplined, evidence-based approach that satisfies statutory obligations while enabling the planned migration to the cloud. Central to this effort is the need to obtain a formal legal ruling that cloud-replicated audit logs satisfy the twelve-month statutory retention requirement. Once such a ruling is secured, the next step is to construct a secure, immutable cloud archive that can be relied upon as the definitive record of system activity. This archive must be presented to the Compliance Authority for explicit sign-off before the legacy data centre can be decommissioned; alternatively, if the cloud solution is deemed insufficient, the on-premises storage lease should be extended to cover the required retention period, thereby avoiding any breach of record-keeping obligations. In parallel with the legal ruling, the programme must expedite a comprehensive legal assessment of the cloud-replicated audit-log storage model. The assessment should culminate in the implementation of a compliant audit-log archive in the cloud, together with a written exemption or a deadline extension from the Compliance Authority. This dual-track approach ensures that the data centre decommission can proceed without contravening statutory requirements, while also providing a clear audit trail for any future regulatory inquiry. A formal legal opinion confirming that the cloud-replicated audit logs meet the statutory twelve-month retention window must be obtained and promptly presented to the Compliance Authority. The purpose of this submission is to lift the current operational block that hampers progress. Should the Authority deem the cloud solution unsatisfactory, the programme must be prepared to negotiate a temporary on-premises storage extension or to adjust the lease expiry so that it aligns with the compliance window. This contingency planning is essential to maintain momentum while respecting regulatory constraints. Securing a formal compliance sign-off that the cloud-based audit logs satisfy the twelve-month statutory record-keeping requirement is another critical milestone. If the Compliance Authority rejects the cloud-based approach, the programme must retain a minimal on-premises archive for the required period and defer the data centre decommission until after 31 March 2027, or negotiate a lease extension that accommodates the statutory window. This decision will directly influence the timing of the cloud migration and must be reflected in the overall project schedule. To facilitate a seamless transition, a formal compliance sign-off should also be obtained for storing the required audit logs in a tamper-proof, cloud-based repository. In the event that the Authority does not grant this sign-off, a statutory extension must be pursued. The migration schedule should be adjusted accordingly, ensuring that the data centre decommission does not breach any statutory record-keeping obligations. Given the inter-dependencies between certification, compliance, and migration, the programme should re-schedule the cloud migration to commence after the earliest possible certification date, which is projected to be post-10 August 2026. An interim certification or provisional approval from the Security Certification Body should be requested to permit limited migration activities while the full test is ongoing. Simultaneously, a temporary compliance waiver or a cloud-based audit-log archive that satisfies the twelve-month statutory requirement must be negotiated, and formal sign-off from the Compliance Authority must be secured before any decommissioning of the data centre. Both issues should be escalated to the Nexus Steering Board for rapid decision-making, ensuring that any bottlenecks are addressed promptly. If the Compliance Authority remains hesitant, a formal compliance waiver must be secured, or the migration plan should be redesigned so that the data centre remains operational until the Authority provides a signed approval. This redesign requires the preparation of a detailed compliance dossier that directly addresses the Authority's concerns, and the acquisition of a signed approval before any decommissioning activity can proceed. The programme closure date of 31 March 2027 is contingent upon the successful completion of the Production Gate milestone. A missed gate triggers a Regulatory Hold that blocks Production Deployment, jeopardising the entire schedule. To mitigate this risk, gate preparation should be front-loaded with the Production Gate approval and all prerequisite assurance packages completed by early December 2026. A thirty-day